

MeoW — Threat Model

Trust architecture and applicative threat scenarios for the MeoW Cat Safety Network

Project: MeoW — Cat Safety Network **Reference ID:** 6A0YB23P **Date:** 7 July 2026

1. Overview

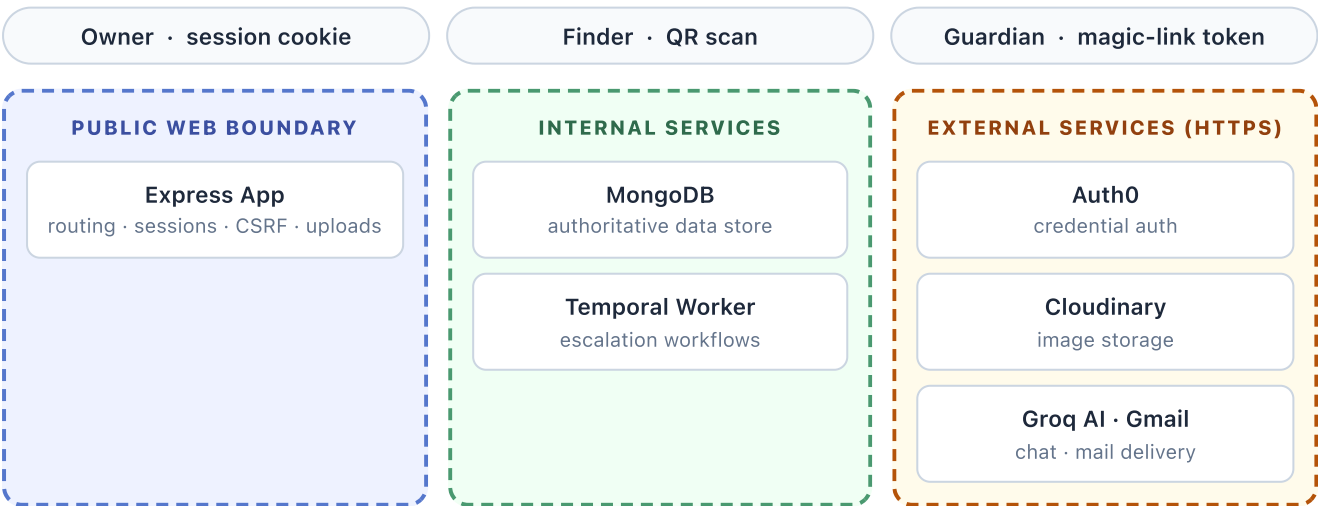
MeoW is a Node.js / Express web application that lets cat owners register pets with QR-code tags, designate trusted guardians, and trigger automated emergency notification workflows when a cat is found or the owner becomes unavailable. Authentication is delegated to Auth0; background escalation runs through Temporal; AI-powered care guidance is served via Groq / LLaMA.

Main components:

- **Express web server** — HTTP routing, session validation, CSRF protection, and file uploads.
- **Auth0** — credential verification and password management for registered owners.
- **MongoDB** — stores users, cats, guardians, sessions, emergency events, and guardian access tokens.
- **Temporal worker** — executes timed escalation workflows for found-cat and owner-unavailable scenarios.
- **Cloudinary** — stores cat and profile photo images.
- **Groq AI** — backs the guardian-facing care-question chat endpoint.
- **Gmail mailer** — delivers owner alerts, guardian magic links, and wallet cards.

This model covers the trust architecture and applicative threat scenarios for the MeoW web application. Implementation-level control weaknesses were remediated and independently verified — see the accompanying **Security Report**.

2. Trust boundaries



FLOW	DESCRIPTION
Owner → Express	HTTPS, authenticated by a MongoDB-backed session cookie with TTL expiry checked on every request.
Finder → Express	HTTPS, unauthenticated; trusted only to submit a QR code and finder contact details.
Guardian → Express	HTTPS, authorised by a magic-link token validated against the database (validity, TTL, invalidation).
Express → Auth0	Credential verification, enforced by client secret.
Express → MongoDB	Queries and writes over the internal boundary; access controlled by connection-string credentials.
Express → Cloudinary / Groq	Image upload and system-prompt-constrained LLM inference.
Express → Temporal → MongoDB	Workflow start; the worker also connects directly to MongoDB for activity execution.

Public Web Boundary. The Express app is the sole internet-facing component. Unauthenticated callers are trusted only to submit a QR code and finder contact details on the scan flow. Authenticated owner routes trust a session cookie, enforced by a MongoDB session lookup with TTL-based expiry on every request. Guardian routes trust a magic-link token parameter, enforced by a database lookup that checks validity, TTL, and invalidation state.

Internal Services Boundary. MongoDB and the Temporal worker are internal backend services not directly reachable from the internet. The Express app trusts MongoDB as the authoritative data store, with access controlled by connection-string credentials. The Temporal worker also connects directly to MongoDB for activity execution, bypassing the Express business layer.

External Services Boundary. Auth0, Cloudinary, Groq AI, and Gmail are third-party SaaS providers reached exclusively over HTTPS. The app trusts Auth0 to verify credentials, Cloudinary to accept and serve images, Groq to execute LLM inference within a system-prompt-constrained context, and Gmail to deliver sensitive magic links and alert emails.

3. Threat scenarios

Each scenario below was identified during threat modelling. The implementation-level weaknesses have since been remediated and verified by an Aikido security scan (all issues resolved); the mitigations are recorded here for completeness.

Unauthenticated scan endpoint enables notification flooding

The `/scan` endpoint is public and requires only a known QR code value to create an emergency event, email the owner, and start a Temporal workflow notifying every guardian in sequence. An adversary who obtains a QR code value (printed on the physical tag) could trigger repeated events from multiple IP addresses.

Risk: High likelihood · Medium impact | **Status:** MITIGATED

- **Mitigation:** A per-IP rate limit (8 / hour) caps finder submissions; a per-QR-code event cap is recommended as a further database-layer control.
- **Validation:** Pentest — submit scan events for the same QR code from distinct IPs and confirm throttling.

Session token remains valid after owner credential reset

An attacker holding a valid session cookie retains access for the remainder of its inactivity window even after the owner resets their password in Auth0, because password changes do not propagate a revocation signal to the custom session layer.

Risk: Medium likelihood · High impact | **Status:** ACCEPTED / ROADMAP

- **Mitigation:** Subscribe to Auth0 post-password-change events and invalidate all sessions for the affected account. Mitigated in practice by a short 30-minute idle TTL.
- **Validation:** Automated test — a session created before a reset is rejected on the next request after the reset.

Prompt injection through user-controlled cat-care fields

An owner can store adversarial instructions in free-text care fields that are interpolated into the Groq system prompt when a guardian uses the chat endpoint, potentially overriding role constraints or extracting prompt contents.

Risk: Medium likelihood · Medium impact | **Status:** PARTIALLY MITIGATED

- **Mitigation:** Care data is sanitised (control characters stripped) and the system prompt instructs the model to treat it as data; recommended hardening is to pass care data in a content-only message role rather than the system role.
- **Validation:** Code review that care fields are delivered in a content-only role; pentest with crafted field values.

Guardian magic link grants care-data access to any bearer

Guardian access tokens are 48-hour UUIDs in email links. Any person who receives, forwards, or intercepts the link can view the owner's profile and cat medical records and invoke the AI chat. Possession of the URL is the sole trust credential.

Risk: Medium likelihood · Medium impact | **Status:** **ACCEPTED / ROADMAP**

- **Mitigation:** Bind token validity to the guardian's registered email and add an out-of-band verification step. Currently bounded by a 48-hour single-use TTL and unguessable UUIDv4 tokens.
- **Validation:** Pentest — open an acknowledged link from an unrelated browser / IP and confirm access controls.

Public scan event pages expose owner and guardian PII

Emergency event status pages at `/scan/:eventId` are accessible without a session or token. A valid event ID yields owner name, guardian names, finder contact details, and cat information; the owner acknowledgment URL contains a one-time suppression token as a query parameter.

Risk: Low likelihood · Medium impact | **Status:** **MITIGATED**

- **Mitigation:** Event IDs are unguessable Mongo ObjectIds; the guardian claim form was removed from the public page, and the acknowledgment token is verified server-side before any escalation suppression takes effect. Recommended further step: restrict the public view to non-personal status indicators only.
- **Validation:** Code review of every field rendered for anonymous requests; pentest with a known event ID.

4. Architectural fragilities

Authorization is split across two independent data-access paths

The Express business layer enforces session validation, ownership checks, and object-level authorization before every database write. The Temporal activity layer, however, connects directly to MongoDB with no shared authorization library, acting on workflow-provided identifiers without re-verifying caller authorization. Any logic added to the activity layer in future bypasses business-layer controls by design, because there is no single enforcing boundary for data mutations.

Current bound: activities only ever run inside trusted, first-party workflows started by the business layer — they never accept external input directly.

Guardian access trust rests on URL secrecy with no identity binding

The guardian access model provides a single security property: possession of the magic-link URL. There is no secondary identity signal (device fingerprint, IP binding, or email re-verification) after

delivery. Because emails are routinely forwarded or exposed, the blast radius of a leaked token is significant for its 48-hour lifetime.

Current bound: tokens are single-use, expire after 48 hours, are invalidated when a peer accepts, and are cryptographically unguessable UUIDv4 values.

Remediation status

All implementation-level findings surfaced by static analysis (Aikido SAST + AI code audit) have been fixed and confirmed **Solved** on re-test. See the Security Report for the full findings-and-resolutions table and scan evidence.